

Security+ 3.2 · Intrusion Prevention

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 3.2** —
Intrusion Prevention (5:14) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: An IPS sits inline (in the traffic path) and actively blocks attacks, whereas an IDS is passive and only detects and alerts. Fail-open mode allows traffic to pass if the device fails (prioritizing availability over security); fail-close mode blocks all traffic on failure (prioritizing security). Misconfigured IPS can block legitimate business traffic via false positives.

High-Yield Core Concepts Tested on Exam

- IPS inline BLOCKS attacks; passive IDS only detects and alerts
- Fail-open = availability; fail-close = security
- IPS misconfiguration can block legitimate business traffic (false positives)
- IDS can operate passively or inline; IPS is always inline
- Two detection modes: detect-and-alert vs. detect-and-block

Exam Tips & Classic Scenarios

- 'blocks attacks inline' = IPS
- 'if the device fails it allows traffic' = fail-open
- 'if the device fails it blocks all traffic' = fail-close

Typical Exam Scenario: An IPS is configured to allow traffic to pass if the device fails. This is fail-open mode, which prioritizes availability over security.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 3.2 — Intrusion Prevention)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Difference between IDS and IPS:

- A)** IDS detects and alerts; IPS detects and BLOCKS
- B)** They are the same thing
- C)** IDS is disk-based; IPS is network-based
- D)** IPS only logs

2. What is the main difference between IDS and IPS?

- A)** IDS blocks attacks, IPS only detects
- B)** IDS only detects and alerts, IPS can actively block
- C)** IDS is physical, IPS is virtual
- D)** IDS operates at layer 2, IPS at layer 3

3. Difference between IDS and IPS:

- A)** IDS detects and alerts; IPS detects and BLOCKS
- B)** They are the same thing
- C)** IDS is disk-based; IPS is network-based
- D)** IPS only logs

4. Corporate scenario (Intrusion Prevention): During a security review and compliance audit for the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Inline IPS BLOCKS; passive IDS ONLY detects/alerts'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Inline IPS BLOCKS; passive IDS ONLY detects/alerts...
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Intrusion Prevention): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Fail-open = availability; fail-close = security'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Fail-open = availability; fail-close = security...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Intrusion Prevention): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Misconfigured IPS = blocking legitimate business traffic (false positive)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Misconfigured IPS = blocking legitimate business traffic (false positive)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Intrusion Prevention): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: "blocks attacks inline" = IPS'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'blocks attacks inline' = IPS...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Intrusion Prevention): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: "if the device fails it allows traffic"=fail-open'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'if the device fails it allows traffic'=fail-open...

9. Corporate scenario (Intrusion Prevention): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: "IPS configured to allow traffic if it fails"=fail-open (availability)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'IPS configured to allow traffic if it fails'=fail-open (availability)....

10. Corporate scenario (Intrusion Prevention): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Inline IPS BLOCKS; passive IDS ONLY detects/alerts'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Inline IPS BLOCKS; passive IDS ONLY detects/alerts...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — IDS detects and alerts; IPS detects and BLOCKS.

✓ **Why it's correct:** The fundamental difference between IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) lies in the action taken after detecting an intrusion. IDS monitors network traffic or system activities for malicious patterns and, upon detection, generates alerts for administrators to investigate. It is passive and does not interfere with data flow. IPS, on the other hand, is active: besides detecting, it blocks or prevents malicious activity in real time, dropping packets, resetting connections, or applying other countermeasures. This distinction is tested in the Security+ (SY0-701) Security Architecture and Design domain, objective 3.2, which covers network security technologies.

✗ **Why the others are wrong:**

- *They are the same thing:* IDS and IPS are distinct technologies with different functions and network placements. IDS is a passive detection system, typically connected to a SPAN port or TAP, analyzing copies of traffic. IPS is an active prevention system, installed inline with the data flow, capable of blocking attacks. Claiming they are the same ignores their operational differences, network impact, and incident response, and contradicts established information security definitions.
- *IDS is disk-based; IPS is network-based:* This statement is incorrect because both can operate on network or host. There are HIDS (Host-based IDS) and HIPS (Host-based IPS), which monitor activities on a single device, including system calls and file integrity. Similarly, NIDS (Network-based IDS) and NIPS (Network-based IPS) analyze network traffic. The distinction is not between disk and network, but between passive detection and active prevention. The alternative confuses monitoring scope with response mechanism.
- *IPS only logs:* This description applies more to an IDS, which typically logs events and emits alerts. IPS is not limited to logging; its primary function is to actively block intrusion attempts. Although many IPS also generate logs for auditing, its defining characteristic is the ability to prevent attacks in real time, taking actions such as dropping malicious packets or terminating sessions. Reducing IPS to a mere log recorder underestimates its critical active protection function.

2) B — IDS only detects and alerts, IPS can actively block.

✓ **Why it is correct:** The correct answer is 'IDS only detects and alerts, IPS can actively block'. In the CompTIA Security+ ecosystem, an IDS (Intrusion Detection System) is a passive monitoring system that inspects network traffic or host activities for attack signatures or behavioral anomalies. Upon identifying a suspicious match, it generates an alert (log, SNMP notification, syslog) for the security team but does not interfere with the data flow. An IPS (Intrusion Prevention System) operates actively and inline (in the traffic path), capable of dropping malicious packets, resetting TCP connections, blocking IP addresses, or applying mitigation policies in real time. The fundamental difference lies in placement and action capability: IDS is an out-of-band sensor (SPAN/TAP), while IPS is an inline device that applies automatic countermeasures. This distinction is crucial for the security objective: detect versus prevent.

✗ **Why the others are wrong:**

- *IDS blocks attacks, IPS only detects:* This option completely reverses the functions. An IDS is by definition a passive detection system: it lacks mechanisms to block traffic because it is typically connected to a switch SPAN port or network TAP, receiving only copies of packets. Its function is to analyze and alert. An IPS, on the other hand, is designed for active prevention, operating inline and applying blocking actions. Therefore, the statement is factually wrong and contradicts CompTIA's conceptual model, which emphasizes the difference between detection (IDS) and prevention (IPS).

- *IDS is physical, IPS is virtual*: This option confuses implementation nature with function. Both IDS and IPS can be implemented as physical appliances, virtual machines, host-based software (HIDS/HIPS), or cloud solutions. The correct classification does not depend on physical or virtual medium, but on response capability: passive detection (IDS) versus active prevention (IPS). CompTIA Security+ does not associate IDS with physical hardware and IPS with virtualization; that distinction is irrelevant to the functional definition of the systems.
- *IDS operates at layer 2, IPS at layer 3*: This option attempts to associate the systems with specific OSI model layers, which is incorrect. IDS and IPS can operate at multiple layers, depending on configuration and analysis type. For example, a network-based IDS (NIDS) can inspect layer 3 (IP) and layer 4 (TCP/UDP) headers, as well as layer 7 (application) payloads. An IPS can also act at various layers, including layer 2 (Ethernet frames) in bridge mode. The statement is a misleading simplification and does not reflect the real architecture of these systems, which are defined by their function (detection vs. prevention) and not by a fixed OSI layer.

3) A — IDS detects and alerts; IPS detects and BLOCKS.

✓ **Why it's correct:** The fundamental difference between IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) lies in the action taken after detecting an intrusion. IDS monitors network traffic or system activities for malicious patterns and, upon detection, generates alerts for administrators to investigate. It is passive and does not interfere with data flow. IPS, on the other hand, is active: besides detecting, it blocks or prevents malicious activity in real time, dropping packets, resetting connections, or applying other countermeasures. This distinction is tested in the Security+ (SY0-701) Security Architecture and Design domain, objective 3.2, which covers network security technologies.

✗ **Why the others are wrong:**

- *They are the same thing*: IDS and IPS are distinct technologies with different functions and network placements. IDS is a passive detection system, typically connected to a SPAN port or TAP, analyzing copies of traffic. IPS is an active prevention system, installed inline with the data flow, capable of blocking attacks. Claiming they are the same ignores their operational differences, network impact, and incident response, and contradicts established information security definitions.
- *IDS is disk-based; IPS is network-based*: This statement is incorrect because both can operate on network or host. There are HIDS (Host-based IDS) and HIPS (Host-based IPS), which monitor activities on a single device, including system calls and file integrity. Similarly, NIDS (Network-based IDS) and NIPS (Network-based IPS) analyze network traffic. The distinction is not between disk and network, but between passive detection and active prevention. The alternative confuses monitoring scope with response mechanism.
- *IPS only logs*: This description applies more to an IDS, which typically logs events and emits alerts. IPS is not limited to logging; its primary function is to actively block intrusion attempts. Although many IPS also generate logs for auditing, its defining characteristic is the ability to prevent attacks in real time, taking actions such as dropping malicious packets or terminating sessions. Reducing IPS to a mere log recorder underestimates its critical active protection function.

4) C — Implement the corresponding solution: Inline IPS BLOCKS; passive IDS ONLY detects/alerts....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Intrusion Prevention): Inline IPS BLOCKS; passive IDS ONLY detects/alerts.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents

and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

5) A — Implement the corresponding solution: Fail-open = availability; fail-close = security....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Intrusion Prevention): Fail-open = availability; fail-close = security. Fail-open means that when a system fails, it defaults to allowing traffic, prioritizing availability. Fail-close means that when a system fails, it defaults to blocking traffic, prioritizing security. The choice between them depends on the organization's risk appetite and the criticality of the asset.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.

6) B — Implement the corresponding solution: Misconfigured IPS = blocking legitimate business traffic (false positive)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Intrusion Prevention): Misconfigured IPS = blocking legitimate business traffic (false positive). An Intrusion Prevention System (IPS) that is not properly tuned can generate false positives, causing it to block legitimate traffic and disrupt business operations. Proper configuration, testing, and monitoring are essential to minimize false positives while maintaining effective threat prevention.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: 'blocks attacks inline' = IPS....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Intrusion Prevention): 'blocks attacks inline' = IPS.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: 'if the device fails it allows traffic'=fail-open....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Intrusion Prevention): 'if the device fails it allows traffic'=fail-open.

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'IPS configured to allow traffic if it fails'=fail-open (availability).....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Intrusion Prevention): 'IPS configured to allow traffic if it fails'=fail-open (availability)..

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) A — Implement the corresponding solution: Inline IPS BLOCKS; passive IDS ONLY detects/alerts....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Intrusion Prevention): Inline IPS BLOCKS; passive IDS ONLY detects/alerts.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.